

SecureMailScope

Cryptographic Security Posture - Forensic Report

Analysis A-20260930-044432-70e8f5 | generated 2026-09-30T04:44:32 UTC | SecureMailScope 1.0.0

Executive summary

167 email sessions across 7 service endpoint(s) were reconstructed from securemail_drift.pcap (3103 packets, 167 TCP streams). The overall cryptographic security posture is 40/100 (grade F).

47 actionable finding(s): 9 critical, 15 high, 17 medium, 6 low (12 informational).

15 session(s) carried mail without any transport encryption; 8 exposed mailbox credentials in cleartext.

20 TLS session(s) negotiated a deprecated protocol version (< TLS 1.2).

The ML engine flagged 30 anomalous session(s) (IsolationForest).

Baseline comparison: drift detected - 12 drift item(s), drift score 100/100.

Highest-priority issues: Credentials exchanged in cleartext (10.0.0.7:110); Credentials exchanged in cleartext (10.0.0.5:143); Credentials exchanged in cleartext (10.0.0.6:587).

Posture	Critical	High	Medium	Low	Sessions	Anomalies
40/100 (F)	9	15	17	6	167	30

Chain of custody

analysis_id	A-20260930-044432-70e8f5
filename	securemail_drift.pcap
sha256	c3f5e927141525b057f2efa39cdd9fac2234980b80f5d10a772b716eebc3cef9
size_bytes	1059037
capture_start	2026-09-28T08:00:21.547283+00:00
capture_end	2026-09-28T09:03:55.097793+00:00
analysed_at	2026-09-30T04:44:32.838432+00:00
analyst	None

Endpoint posture

Endpoint	Proto	Sess.	Score	Transp.	Proto	Cipher	Cert
10.0.0.5:993 (mail.company.com)	IMAP	71	0 (F)	100	58	64	86
10.0.0.8:465 (legacy-mx.company.com)	SMTP	4	5 (F)	100	71	81	53
10.0.0.7:110	POP3	3	62 (D)	62	100	100	100
10.0.0.6:587 (mail.company.com)	SMTP	43	64 (D)	68	100	100	100
10.0.0.5:143 (mail.company.com)	IMAP	12	78 (C)	78	100	100	100
10.0.0.7:995 (mail.company.com)	POP3	12	81 (B)	100	100	89	92
10.0.0.6:25 (mail.company.com)	SMTP	22	81 (B)	95	100	100	100

Prioritised findings

#	Pri	Severity	Finding / detail	Endpoint	Aff.
1	P1	CRITICAL	Credentials exchanged in cleartext POP3 USER/PASS credentials sent unencrypted (user al***)	10.0.0.7:110	3/3
2	P1	CRITICAL	Credentials exchanged in cleartext IMAP LOGIN credentials sent unencrypted (user al***)	10.0.0.5:143	2/12

#	Pri	Severity	Finding / detail	Endpoint	Aff.
3	P1	CRITICAL	Credentials exchanged in cleartext SMTP PLAIN credentials sent unencrypted (user al***)	10.0.0.6:587	3/43
4	P1	CRITICAL	Drift: STARTTLS no longer offered / honoured - possible stripping Baseline: STARTTLS offered in 100% of negotiating sessions Current: 7 session(s) without a successful STARTTLS upgrade	10.0.0.6:25	7/22
5	P1	CRITICAL	STARTTLS upgrade refused - possible stripping / downgrade SMTP server replied '454 4.7.0 TLS not available due to local problem' to STARTTLS; session continued in cleartext with authentication	10.0.0.6:587	3/43
6	P1	CRITICAL	Drift: STARTTLS no longer offered / honoured - possible stripping Baseline: STARTTLS offered in 100% of negotiating sessions Current: 2 session(s) without a successful STARTTLS upgrade	10.0.0.5:143	2/12
7	P1	CRITICAL	Drift: STARTTLS no longer offered / honoured - possible stripping Baseline: STARTTLS offered in 100% of negotiating sessions Current: 3 session(s) without a successful STARTTLS upgrade	10.0.0.6:587	3/43
8	P1	CRITICAL	Drift: Insecure cipher suite(s) newly negotiated: TLS_ECDHE_RSA_WITH_RC4_128_SHA Baseline: TLS_AES_128_GCM_SHA256, TLS_AES_256_GCM_SHA384, TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256, TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 Current: TLS_AES_128_GC	10.0.0.5:993	2/71
9	P1	CRITICAL	Insecure cipher suite negotiated TLS_ECDHE_RSA_WITH_RC4_128_SHA: RC4 keystream biases (RFC 7465 prohibits)	10.0.0.5:993	2/71
10	P1	HIGH	Deprecated protocol version negotiated - TLS 1.0 negotiated TLS 1.0	10.0.0.8:465	4/4
11	P1	HIGH	Server certificate expired expired 2024-01-01	10.0.0.8:465	4/4
12	P1	HIGH	Weak RSA key length - RSA-1024 RSA-1024	10.0.0.8:465	4/4
13	P2	HIGH	Drift: Certificate change detected Baseline: A0:A8:74:90:70:CD:07:01... (Synthetic Corp Issuing CA, RSA-2048, valid 2026-01-10 -> 2027-01-10) Current: D9:2D:BD:8F:A2:F2:26:E6... (Unknown Trust	10.0.0.5:993	38/71
14	P2	HIGH	Certificate chain not trusted issuer Unknown Trust Services CA not trusted	10.0.0.5:993	38/71
15	P2	HIGH	Drift: Forward-secrecy coverage dropped 100% -> 79% Baseline: 100% PFS Current: 79% PFS	10.0.0.5:993	14/71
16	P2	HIGH	Drift: TLS 1.1 traffic detected Baseline: TLS 1.2 / TLS 1.3 only Current: TLS 1.0 / TLS 1.1 / TLS 1.2 / TLS 1.3	10.0.0.5:993	14/71
17	P2	HIGH	Drift: Weak cipher suite(s) newly negotiated: TLS_RSA_WITH_3DES_EDE_CBC_SHA Baseline: TLS_AES_128_GCM_SHA256, TLS_AES_256_GCM_SHA384, TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256, TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 Current: TLS_AES_128_GC	10.0.0.5:993	14/71
18	P2	HIGH	Drift: TLS 1.0 traffic detected Baseline: TLS 1.2 / TLS 1.3 only Current: TLS 1.0 / TLS 1.1 / TLS 1.2 / TLS 1.3	10.0.0.5:993	2/71
19	P2	MEDIUM	Drift: Certificate change detected Baseline: A0:A8:74:90:70:CD:07:01... (Synthetic Corp Issuing CA, RSA-2048, valid 2026-01-10 -> 2027-01-10) Current: 06:6C:89:64:7D:58:E5:49... (Synthetic Corp	10.0.0.7:995	12/12
20	P2	HIGH	Anomalous TLS session behaviour (ML) 21 anomalous session(s); top score 0.83 - Negotiated TLS version = TLS 1.1 (seen in 0.0% of reference sessions); Cipher-suite strength grade = weak (seen in 0.0	10.0.0.5:993	21/71
21	P2	HIGH	Deprecated protocol version negotiated - TLS 1.1 negotiated TLS 1.1	10.0.0.5:993	14/71
22	P2	HIGH	Weak cipher suite negotiated (3DES) TLS_RSA_WITH_3DES_EDE_CBC_SHA	10.0.0.5:993	14/71

#	Pri	Severity	Finding / detail	Endpoint	Aff.
23	P2	HIGH	Weak Diffie-Hellman parameters DHE prime 1024 bits	10.0.0.7:995	2/12
24	P2	HIGH	Deprecated protocol version negotiated - TLS 1.0 negotiated TLS 1.0	10.0.0.5:993	2/71
25	P2	MEDIUM	Authentication mechanisms offered before TLS server advertises USER/PASS before TLS	10.0.0.7:110	3/3
26	P2	MEDIUM	Client offers insecure or weak cipher suites - insecure suites offered 2 weak/insecure suites offered (e.g. TLS_RSA_WITH_RC4_128_SHA)	10.0.0.8:465	4/4
27	P2	MEDIUM	No forward secrecy key exchange RSA (TLS_RSA_WITH_AES_256_CBC_SHA)	10.0.0.8:465	4/4
28	P2	MEDIUM	Server certificate expiring soon 11 day(s) remaining	10.0.0.7:995	12/12
29	P2	HIGH	TLS downgrade sentinel present in ServerHello downgrade sentinel for TLS 1.2 in ServerHello.random	10.0.0.5:993	2/71
30	P2	MEDIUM	Secure renegotiation not supported no renegotiation_info in ServerHello	10.0.0.8:465	4/4
31	P2	MEDIUM	Self-signed server certificate CN=legacy-mx.company.com	10.0.0.8:465	4/4
32	P3	MEDIUM	Email session without transport encryption - STARTTLS not offered server does not offer STARTTLS/TLS	10.0.0.6:25	7/22
33	P3	MEDIUM	Client offers insecure or weak cipher suites - insecure suites offered 2 weak/insecure suites offered (e.g. TLS_RSA_WITH_RC4_128_SHA)	10.0.0.5:993	19/71
34	P3	MEDIUM	Anomalous TLS session behaviour (ML) 7 anomalous session(s); top score 0.62 - Negotiated TLS version = none (seen in 0.0% of reference sessions); Cipher-suite strength grade = none (seen in 0.0% of	10.0.0.6:25	7/22
35	P3	MEDIUM	No forward secrecy key exchange RSA (TLS_RSA_WITH_3DES_EDE_CBC_SHA)	10.0.0.5:993	14/71
36	P3	MEDIUM	Authentication mechanisms offered before TLS server advertises LOGIN before TLS	10.0.0.5:143	2/12
37	P3	LOW	CBC-mode cipher suite negotiated TLS_RSA_WITH_AES_256_CBC_SHA	10.0.0.8:465	4/4
38	P3	LOW	Certificate lacks Subject Alternative Name no SAN extension	10.0.0.8:465	4/4
39	P3	LOW	Client offers deprecated protocol versions offers TLS 1.0	10.0.0.8:465	4/4
40	P3	MEDIUM	Secure renegotiation not supported no renegotiation_info in ServerHello	10.0.0.5:993	16/71
41	P3	MEDIUM	Message-level protection over plaintext transport protected message carried over unencrypted transport	10.0.0.6:25	2/22
42	P3	MEDIUM	Anomalous TLS session behaviour (ML) 2 anomalous session(s); top score 0.66 - Negotiated TLS version = none (seen in 0.0% of reference sessions); Cipher-suite strength grade = none (seen in 0.0% of	10.0.0.6:587	2/43
43	P3	MEDIUM	OpenPGP message without integrity protection 1 message(s) without MDC	10.0.0.6:25	1/22
44	P3	MEDIUM	Client protocol fallback (TLS_FALLBACK_SCSV) TLS_FALLBACK_SCSV in ClientHello	10.0.0.5:993	2/71
45	P4	LOW	Drift: New key-exchange mechanism(s): DHE Baseline: ECDHE Current: DHE, ECDHE	10.0.0.7:995	2/12
52	P4	LOW	Client offers deprecated protocol versions offers TLS 1.1	10.0.0.5:993	16/71
55	P4	LOW	TLS handshake failed or fatal alert observed no ServerHello observed	10.0.0.5:993	3/71

Cryptographic drift vs baseline (status DRIFT_DETECTED, score 100/100)

STARTTLS no longer offered / honoured - possible stripping [CRITICAL] 10.0.0.6:587

Baseline	STARTTLS offered in 100% of negotiating sessions
Current	3 session(s) without a successful STARTTLS upgrade
Affected sessions	3
Evidence	TCP stream 0 / server capabilities / starttls_advertised = True
Why it matters	The baseline server always supported encryption; its disappearance is the hallmark of a STARTTLS stripping/downgrade attack or a broken TLS configuration.
Recommendation	Check for on-path devices altering SMTP/IMAP/POP3 capabilities, verify server TLS config, and enforce MTA-STS/DANE.

Insecure cipher suite(s) newly negotiated: TLS_ECDHE_RSA_WITH_RC4_128_SHA [CRITICAL] 10.0.0.5:993

Baseline	TLS_AES_128_GCM_SHA256, TLS_AES_256_GCM_SHA384, TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256, TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384
Current	TLS_AES_128_GCM_SHA256, TLS_AES_256_GCM_SHA384, TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256, TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384, TLS_ECDHE_RSA_WITH_RC4_128_SHA, TLS_RSA_WITH_3DES_EDE_CBC_SHA
Affected sessions	2
Evidence	TCP stream 97 / ServerHello / cipher_suite = TLS_ECDHE_RSA_WITH_RC4_128_SHA
Why it matters	Cipher suites outside the baseline indicate a configuration change or a client forcing weaker algorithms.
Recommendation	Restrict the server cipher list to AEAD+ECDHE suites and identify the client that selected this suite.

STARTTLS no longer offered / honoured - possible stripping [CRITICAL] 10.0.0.5:143

Baseline	STARTTLS offered in 100% of negotiating sessions
Current	2 session(s) without a successful STARTTLS upgrade
Affected sessions	2
Evidence	TCP stream 67 / server capabilities / starttls_advertised = False
Why it matters	The baseline server always supported encryption; its disappearance is the hallmark of a STARTTLS stripping/downgrade attack or a broken TLS configuration.
Recommendation	Check for on-path devices altering SMTP/IMAP/POP3 capabilities, verify server TLS config, and enforce MTA-STS/DANE.

STARTTLS no longer offered / honoured - possible stripping [CRITICAL] 10.0.0.6:25

Baseline	STARTTLS offered in 100% of negotiating sessions
Current	7 session(s) without a successful STARTTLS upgrade
Affected sessions	7
Evidence	TCP stream 48 / server capabilities / starttls_advertised = False
Why it matters	The baseline server always supported encryption; its disappearance is the hallmark of a STARTTLS stripping/downgrade attack or a broken TLS configuration.
Recommendation	Check for on-path devices altering SMTP/IMAP/POP3 capabilities, verify server TLS config, and enforce MTA-STS/DANE.

TLS 1.0 traffic detected [HIGH] 10.0.0.5:993

Baseline	TLS 1.2 / TLS 1.3 only
Current	TLS 1.0 / TLS 1.1 / TLS 1.2 / TLS 1.3
Affected sessions	2
Evidence	TCP stream 97 / ServerHello / negotiated_version = TLS 1.0
Why it matters	TLS 1.0 is deprecated (RFC 8996) and vulnerable to downgrade and padding-oracle attacks; it was absent from the baseline.
Recommendation	Investigate the server/client configuration responsible for negotiating TLS 1.0; disable it on the server and upgrade the legacy client.

TLS 1.1 traffic detected [HIGH] 10.0.0.5:993	
Baseline	TLS 1.2 / TLS 1.3 only
Current	TLS 1.0 / TLS 1.1 / TLS 1.2 / TLS 1.3
Affected sessions	14
Evidence	TCP stream 3 / ServerHello / negotiated_version = TLS 1.1
Why it matters	TLS 1.1 is deprecated (RFC 8996) and vulnerable to downgrade and padding-oracle attacks; it was absent from the baseline.
Recommendation	Investigate the server/client configuration responsible for negotiating TLS 1.1; disable it on the server and upgrade the legacy client.

Weak cipher suite(s) newly negotiated: TLS_RSA_WITH_3DES_EDE_CBC_SHA [HIGH] 10.0.0.5:993	
Baseline	TLS_AES_128_GCM_SHA256, TLS_AES_256_GCM_SHA384, TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256, TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384
Current	TLS_AES_128_GCM_SHA256, TLS_AES_256_GCM_SHA384, TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256, TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384, TLS_ECDHE_RSA_WITH_RC4_128_SHA, TLS_RSA_WITH_3DES_EDE_CBC_SHA
Affected sessions	14
Evidence	TCP stream 3 / ServerHello / cipher_suite = TLS_RSA_WITH_3DES_EDE_CBC_SHA
Why it matters	Cipher suites outside the baseline indicate a configuration change or a client forcing weaker algorithms.
Recommendation	Restrict the server cipher list to AEAD+ECDHE suites and identify the client that selected this suite.

Forward-secrecy coverage dropped 100% -> 79% [HIGH] 10.0.0.5:993	
Baseline	100% PFS
Current	79% PFS
Affected sessions	14
Evidence	TCP stream 3 / ServerHello / key_exchange = RSA
Why it matters	Sessions without ephemeral key exchange can be decrypted later if the server key leaks.
Recommendation	Remove static RSA key-exchange suites; require ECDHE/DHE.

Certificate change detected [HIGH] 10.0.0.5:993	
Baseline	A0:A8:74:90:70:CD:07:01... (Synthetic Corp Issuing CA, RSA-2048, valid 2026-01-10 -> 2027-01-10)
Current	D9:2D:BD:8F:A2:F2:26:E6... (Unknown Trust Services CA, RSA-2048, valid 2026-09-20 -> 2027-09-20)
Affected sessions	38
Observations	Issuer changed: Synthetic Corp Issuing CA -> Unknown Trust Services CA; New certificate does not chain to a trusted root (previous one did)
Evidence	TCP stream 2 / Certificate / fingerprint_sha256 = D9:2D:BD:8F:A2:F2:26:E6:95:1B:D7:D5:25:FE:B7:26:E6
Why it matters	Unexpected certificate replacement or a new issuer can indicate TLS interception, an unauthorised CA, or an uncontrolled change.
Recommendation	Investigate certificate replacement: confirm the change ticket, issuer authorisation and that no interception device is in path.

Certificate change detected [MEDIUM] 10.0.0.7:995	
Baseline	A0:A8:74:90:70:CD:07:01... (Synthetic Corp Issuing CA, RSA-2048, valid 2026-01-10 -> 2027-01-10)
Current	06:6C:89:64:7D:58:E5:49... (Synthetic Corp Issuing CA, RSA-2048, valid 2025-10-05 -> 2026-10-10)
Affected sessions	12
Observations	Same issuer, key and subject; only the fingerprint/validity window changed; Previous certificate still had >30 days validity: unscheduled replacement
Evidence	TCP stream 4 / Certificate / fingerprint_sha256 = 06:6C:89:64:7D:58:E5:49:C5:DA:DB:5E:9D:4E:10:0A:7F
Why it matters	Unexpected certificate replacement or a new issuer can indicate TLS interception, an unauthorised CA, or an uncontrolled change.
Recommendation	Investigate certificate replacement: confirm the change ticket, issuer authorisation and that no interception device is in path.

New key-exchange mechanism(s): DHE [LOW] 10.0.0.7:995	
Baseline	ECDHE
Current	DHE, ECDHE
Affected sessions	2
Evidence	TCP stream 4 / ServerKeyExchange / key_exchange = DHE
Why it matters	Key exchange profile differs from baseline.
Recommendation	Confirm the change is intentional.

New strong cipher suite(s) observed: TLS_DHE_RSA_WITH_AES_128_GCM_SHA256 [INFO] 10.0.0.7:995	
Baseline	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256, TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384
Current	TLS_DHE_RSA_WITH_AES_128_GCM_SHA256, TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256
Affected sessions	2
Evidence	TCP stream 4 / ServerHello / cipher_suite = TLS_DHE_RSA_WITH_AES_128_GCM_SHA256
Why it matters	Baseline expansion with strong crypto.
Recommendation	Update baseline if intended.

Highest-risk sessions (explainable assessment)

SESSION #160 - IMAP 10.0.1.164:45203 -> 10.0.0.5:993	
CRITICAL 100/100	
Transport	Implicit TLS [OK]
TLS Version	TLS 1.0 [FAIL]
Cipher Suite	ECDHE_RSA_WITH_RC4_128_SHA [FAIL]
Key Exchange	ECDHE (secp256r1) [OK]
Certificate	Untrusted issuer (RSA-2048, SHA256) [WARN]
ML Anomaly Score	0.61 [WARN]
Why	Insecure cipher suite negotiated: TLS_ECDHE_RSA_WITH_RC4_128_SHA: RC4 keystream biases (RFC 7465 prohibits); Deprecated protocol version negotiated - TLS 1.0: negotiated TLS 1.0; Certificate chain not trusted: issuer Unknown Trust Services CA not trusted; Secure renegotiation not supported: no renegotiation_info in ServerHello
Recommendation	Remove insecure suites from the server cipher list immediately. Disable TLS < 1.2 on the server. Install a certificate from a trusted CA and serve the full chain.

SESSION #0 - SMTP 10.0.1.67:43062 -> 10.0.0.6:587	
CRITICAL 99/100	
Transport	Plaintext [FAIL]
ML Anomaly Score	0.66 [WARN]
Why	STARTTLS upgrade refused - possible stripping / downgrade: SMTP server replied '454 4.7.0 TLS not available due to local problem' to STARTTLS; session continued in cleartext with authentication; Credentials exchanged in cleartext: SMTP PLAIN credentials sent unencrypted (user al***); ML: Negotiated TLS version = none (seen in 0.0% of reference sessions); ML: Cipher-suite strength grade = none (seen in 0.0% of reference sessions)
Recommendation	Investigate middleboxes/proxies on the path that may rewrite STARTTLS responses. Require TLS before authentication (disable plaintext auth).

SESSION #3 - IMAP 10.0.1.183:46493 -> 10.0.0.5:993	CRITICAL 99/100
Transport	Implicit TLS [OK]
TLS Version	TLS 1.1 [FAIL]
Cipher Suite	RSA_WITH_3DES_EDE_CBC_SHA [WARN]
Key Exchange	RSA [WARN]
Certificate	Untrusted issuer (RSA-2048, SHA256) [WARN]
ML Anomaly Score	0.61 [WARN]
Why	Deprecated protocol version negotiated - TLS 1.1: negotiated TLS 1.1; Weak cipher suite negotiated (3DES): TLS_RSA_WITH_3DES_EDE_CBC_SHA; Certificate chain not trusted: issuer Unknown Trust Services CA not trusted; Secure renegotiation not supported: no renegotiation_info in ServerHello
Recommendation	Disable TLS < 1.2 on the server. Disable 3DES suites. Install a certificate from a trusted CA and serve the full chain.
SESSION #40 - IMAP 10.0.1.162:40848 -> 10.0.0.5:993	CRITICAL 99/100
Transport	Implicit TLS [OK]
TLS Version	TLS 1.1 [FAIL]
Cipher Suite	RSA_WITH_3DES_EDE_CBC_SHA [WARN]
Key Exchange	RSA [WARN]
Certificate	Untrusted issuer (RSA-2048, SHA256) [WARN]
ML Anomaly Score	0.61 [WARN]
Why	Deprecated protocol version negotiated - TLS 1.1: negotiated TLS 1.1; Weak cipher suite negotiated (3DES): TLS_RSA_WITH_3DES_EDE_CBC_SHA; Certificate chain not trusted: issuer Unknown Trust Services CA not trusted; Secure renegotiation not supported: no renegotiation_info in ServerHello
Recommendation	Disable TLS < 1.2 on the server. Disable 3DES suites. Install a certificate from a trusted CA and serve the full chain.
SESSION #42 - IMAP 10.0.1.129:50121 -> 10.0.0.5:993	CRITICAL 99/100
Transport	Implicit TLS [OK]
TLS Version	TLS 1.1 [FAIL]
Cipher Suite	RSA_WITH_3DES_EDE_CBC_SHA [WARN]
Key Exchange	RSA [WARN]
Certificate	Untrusted issuer (RSA-2048, SHA256) [WARN]
ML Anomaly Score	0.66 [WARN]
Why	Deprecated protocol version negotiated - TLS 1.1: negotiated TLS 1.1; Weak cipher suite negotiated (3DES): TLS_RSA_WITH_3DES_EDE_CBC_SHA; Certificate chain not trusted: issuer Unknown Trust Services CA not trusted; Secure renegotiation not supported: no renegotiation_info in ServerHello
Recommendation	Disable TLS < 1.2 on the server. Disable 3DES suites. Install a certificate from a trusted CA and serve the full chain.

SESSION #43 - SMTP 10.0.1.198:55896 -> 10.0.0.8:465	CRITICAL 99/100
Transport	Implicit TLS [OK]
TLS Version	TLS 1.0 [FAIL]
Cipher Suite	RSA_WITH_AES_256_CBC_SHA [INFO]
Key Exchange	RSA [WARN]
Certificate	Expired (RSA-1024, SHA256) [FAIL]
ML Anomaly Score	0.47 [OK]
Why	Deprecated protocol version negotiated - TLS 1.0: negotiated TLS 1.0; Server certificate expired: expired 2024-01-01; Weak RSA key length - RSA-1024: RSA-1024; Secure renegotiation not supported: no renegotiation_info in ServerHello
Recommendation	Disable TLS < 1.2 on the server. Renew and deploy a new certificate. Re-issue with RSA >=2048 (3072 recommended) or ECDSA P-256.
SESSION #46 - SMTP 10.0.1.121:51502 -> 10.0.0.6:587	CRITICAL 99/100
Transport	Plaintext [FAIL]
ML Anomaly Score	0.63 [WARN]
Why	STARTTLS upgrade refused - possible stripping / downgrade: SMTP server replied '454 4.7.0 TLS not available due to local problem' to STARTTLS; session continued in cleartext with authentication; Credentials exchanged in cleartext: SMTP PLAIN credentials sent unencrypted (user al***); ML: Negotiated TLS version = none (seen in 0.0% of reference sessions); ML: Cipher-suite strength grade = none (seen in 0.0% of reference sessions)
Recommendation	Investigate middleboxes/proxies on the path that may rewrite STARTTLS responses. Require TLS before authentication (disable plaintext auth).
SESSION #57 - SMTP 10.0.1.170:45898 -> 10.0.0.8:465	CRITICAL 99/100
Transport	Implicit TLS [OK]
TLS Version	TLS 1.0 [FAIL]
Cipher Suite	RSA_WITH_AES_256_CBC_SHA [INFO]
Key Exchange	RSA [WARN]
Certificate	Expired (RSA-1024, SHA256) [FAIL]
ML Anomaly Score	0.49 [OK]
Why	Deprecated protocol version negotiated - TLS 1.0: negotiated TLS 1.0; Server certificate expired: expired 2024-01-01; Weak RSA key length - RSA-1024: RSA-1024; Secure renegotiation not supported: no renegotiation_info in ServerHello
Recommendation	Disable TLS < 1.2 on the server. Renew and deploy a new certificate. Re-issue with RSA >=2048 (3072 recommended) or ECDSA P-256.

Certificates

Subject	Issuer	Key	Hash	Valid to	Days
mail.company.com D9:2D:BD:8F:A2:F2:26:E6...	Unknown Trust Services CA	RSA-2048	sha256	2027-09-20	356
mail.company.com 06:6C:89:64:7D:58:E5:49...	Synthetic Corp Issuing CA	RSA-2048	sha256	2026-10-10	11
Synthetic Corp Issuing CA 53:47:5F:3C:72:FC:78:73...	Synthetic Corp Root CA	RSA-2048	sha256	2035-01-01	3016
mail.company.com A0:A8:74:90:70:C D:07:01...	Synthetic Corp Issuing CA	RSA-2048	sha256	2027-01-10	103
legacy-mx.company.com C9:48:B8:41:A4:C7:53:80...	legacy-mx.company.com	RSA-1024	sha256	2024-01-01	-1002

Remediation plan

Pri	Action	Effort	Resolves
P1	Require TLS before authentication (disable plaintext auth).	low	TR-001
P1	Force password resets for the exposed accounts.	low	TR-001
P1	Check for on-path devices altering SMTP/IMAP/POP3 capabilities, verify server TLS config, and enforce MTA-STS/DANE.	medium	DR-TRANSPORT
P1	Investigate middleboxes/proxies on the path that may rewrite STARTTLS responses.	medium	TR-003
P1	Configure clients to require TLS (never fall back to plaintext).	medium	TR-003
P1	Restrict the server cipher list to AEAD+ECDHE suites and identify the client that selected this suite.	medium	DR-CIPHER
P1	Remove insecure suites from the server cipher list immediately.	low	CS-001
P1	Disable TLS < 1.2 on the server.	low	TLS-001
P1	Identify and upgrade/replace the client that only supports legacy TLS.	low	TLS-001
P1	Renew and deploy a new certificate.	low	CE-001
P1	Automate renewal (ACME).	low	CE-001
P1	Re-issue with RSA >=2048 (3072 recommended) or ECDSA P-256.	medium	CE-008
P2	Investigate certificate replacement: confirm the change ticket, issuer authorisation and that no interception device is in path.	medium	DR-CERT
P2	Install a certificate from a trusted CA and serve the full chain.	medium	CE-005
P2	Add your enterprise CA to production_artifacts/trust_store/ if private.	medium	CE-005
P2	Remove static RSA key-exchange suites; require ECDHE/DHE.	medium	DR-PFS
P2	Investigate the server/client configuration responsible for negotiating TLS 1.1; disable it on the server and upgrade the legacy client.	medium	DR-TLS
P2	Investigate the server/client configuration responsible for negotiating TLS 1.0; disable it on the server and upgrade the legacy client.	medium	DR-TLS

Methodology & limitations

- Analysis is passive: TLS 1.3 encrypts the server certificate, so chain validation is only possible for TLS <= 1.2 handshakes (or resumed-free full handshakes).
- Encrypted mail content cannot be inspected; PGP/S-MIME detection applies to plaintext streams only.
- Trust evaluation uses the Mozilla CA bundle plus any enterprise CAs in production_artifacts/trust_store; revocation (OCSP/CRL) is not checked offline.
- ML anomaly scores are statistical indicators, not proof of attack; always correlate with rule findings and change records.
- Drift results are only as good as the baseline: a baseline captured during an insecure period encodes that insecurity as normal.